

Chapter 1

Introduction to Computer Security

Introduction

- Computer security relies on a framework of policies, technical mechanisms (firewalls, encryption), and physical controls to ensure confidentiality, integrity, and availability.
- It's Prevention (firewalls, training) stops attacks, detection (IDS, monitoring) identifies breaches, and deterrence (banners, policies) discourages threats.
- **Software assurance** integrates security into the development lifecycle

threats

- Computer security threats are malicious actions or vulnerabilities, such as malware, phishing, ransomware, and insider attacks, designed to damage, steal, or compromise data and system functionality.
- These evolving threats range from viruses and Trojans to sophisticated, targeted attacks like zero-day exploits and SQL injections, which can cause significant, often irreversible damage to individuals and organizations.

Key Types of Computer Security Threats

- **Malware (Malicious Software)**: Software designed to disrupt, damage, or gain unauthorized access to a computer system. Common types include viruses, worms, spyware, and Trojans.
- **Ransomware**: A type of malware that encrypts a victim's files, with attackers demanding a ransom for the decryption key.
- **Phishing**: Deceptive emails, websites, or messages designed to steal sensitive information like login credentials and credit card numbers.
- **Man-in-the-Middle (MitM) Attacks**: Attackers intercept communication between two parties, often on unsecure Wi-Fi, to steal data.
- **Denial-of-Service (DoS/DDoS) Attacks**: Flooding a system or network with traffic to overload it, rendering it unusable.
- **Zero-Day Exploits**: Attacks targeting previously unknown software or hardware vulnerabilities before a patch is available.
- **SQL Injection**: A technique where attackers insert malicious code into a server that uses SQL, forcing it to reveal protected information.
- **Insider Threats**: Security risks originating from within an organization, such as employees or contractors with authorized access.

Prevention and Mitigation Strategies

- **Antivirus/Anti-Malware Software:** Install and regularly update reputable security software.
- **Software Updates:** Keep operating systems and applications updated to patch known vulnerabilities.
- **Strong Authentication:** Use complex, unique passwords and enable multi-factor authentication (MFA).
- **Backup Data:** Regularly back up critical data to secure, off-site locations to mitigate ransomware impacts.
- **User Education:** Train users to recognize phishing attempts and suspicious links.

Computer vulnerability

- It's a weakness, flaw, or error in a computer system's security procedures, design, implementation, or internal controls that can be exploited by a threat actor to gain unauthorized access, steal data, or disrupt operations.
- Vulnerabilities are essentially the "holes" in a system's defenses that allow malicious activities to succeed.

Vulnerabilities

- Vulnerabilities are generally categorized into four main domains:
- 1. Technical & Software Vulnerabilities**
 - These are flaws in the design, implementation, or maintenance of code and hardware.
 - Unpatched Software & Zero-Days: Known bugs that haven't been fixed (unpatched) or new bugs that the developers aren't aware of yet (Zero-Day).
 - Injection Flaws: When a system fails to "clean" user input, allowing attackers to send malicious commands (e.g., SQL Injection or Cross-Site Scripting (XSS)).

- **Broken Authentication:** Weaknesses in how a system verifies who you are, such as allowing simple passwords or having "leaky" session tokens that can be stolen.
- **API Vulnerabilities:** Vulnerabilities here often involve "excessive data exposure," where an API accidentally sends more information than necessary to a user.
- **Buffer Overflows:** A classic flaw where an application writes more data to a block of memory than it can hold, often crashing the system or allowing malicious code to run.

2. Configuration & Infrastructure Vulnerabilities

- Even "perfect" software is vulnerable if it is set up incorrectly.
- **Security Misconfigurations:** Using default usernames/passwords (like admin/password), leaving unused ports open, or keeping "cloud storage buckets" (like AWS S3) public when they should be private.

Cont..

3. Policy Vulnerabilities

- These are weaknesses that stem from a lack of written rules, procedures, or security management. If the "playbook" for security is missing or poorly written, the technical defenses don't matter.
- **Key Issues:** No security awareness training for staff, lack of a clear password policy, no "Incident Response Plan," or failing to have a data classification policy (not knowing what data is "Top Secret" vs. "Public").
- **The Result:** Employees don't know how to handle sensitive info, and there's no plan of action when an attack actually happens.

Cont..

4. Hardware Vulnerabilities

- These are flaws in the physical design or protection of the devices themselves.
- If an attacker can get their hands on a device, they can often bypass all the software security you've installed.
- **Key Issues:** Lack of physical locks on server rooms, "hard-coded" passwords in a device's firmware that can't be changed, or susceptibility to environmental factors (like a server overheating because the room isn't cooled).
- **The Result:** An attacker could plug a malicious device into a server, steal a hard drive, or simply cut the power to shut down your entire network.

Goals of computer security

- The primary goals of computer security, known as the CIA Triad, are to ensure:
- **Confidentiality** (data access only by authorized users),
- **Integrity** (data accuracy and protection from unauthorized modification), and
- **Availability** (reliable access to resources). These foundational principles aim to protect systems, networks, and data from theft, damage, or unauthorized access.

Core Goals of Computer Security

- **Confidentiality**: Ensures that sensitive information is accessed only by authorized individuals or systems, often using encryption, access controls, and authentication mechanisms.
- **Integrity**: Protects data from being modified or corrupted by unauthorized parties, maintaining information accuracy and trustworthiness through methods like hashing, checksums, and digital signatures.
- **Availability**: Guarantees that authorized users have reliable and timely access to systems and data, preventing disruptions from attacks (like DDoS) or system failures through redundancy, backups, and maintenance

Cont..

Additional Objectives

- **Authentication**: Verifies the identity of users or systems, such as through multi-factor authentication (MFA).
- **Non-repudiation**: Ensures that individuals cannot deny their actions (e.g., signing a document or sending a message).
- **Risk Management**: Identifies, assesses, and mitigates security risks

Security attack

Attacks splits into two high-level buckets based on their behavior:

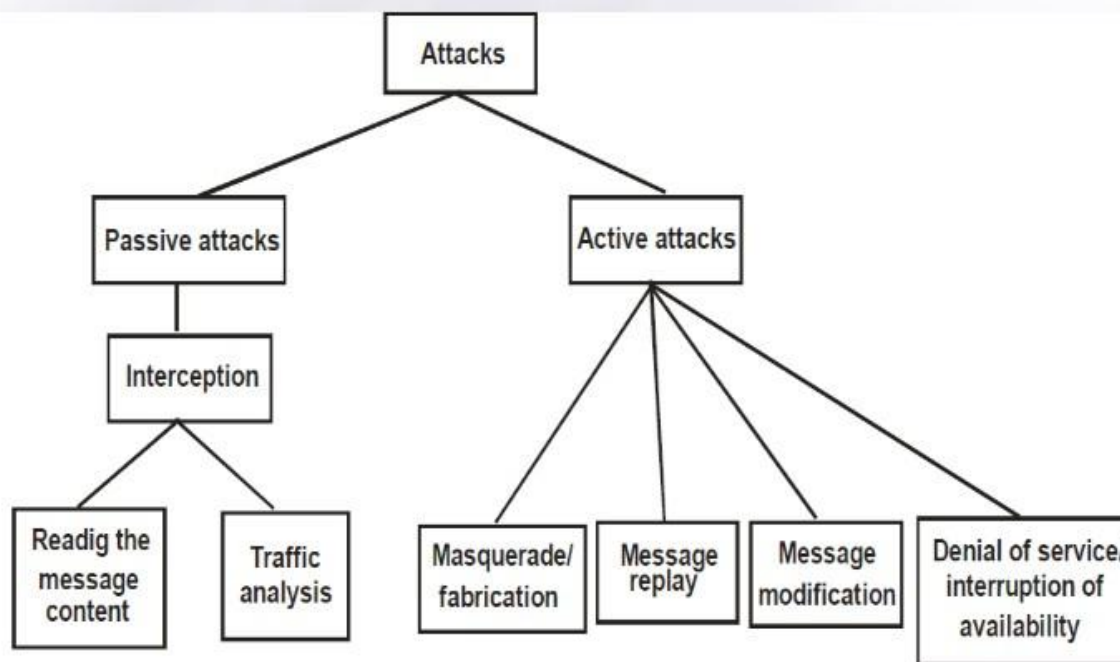
❑ **Active Attacks:** The attacker attempts to alter system resources or affect their operation.

➤ *Examples:* Ransomware, DDoS, SQL Injection, and Data Modification.

❑ **Passive Attacks:** The attacker attempts to learn or make use of information from the system but does not affect system resources (often called "Eavesdropping").

➤ *Examples:* Traffic Analysis, Packet Sniffing, and Monitoring of communications.

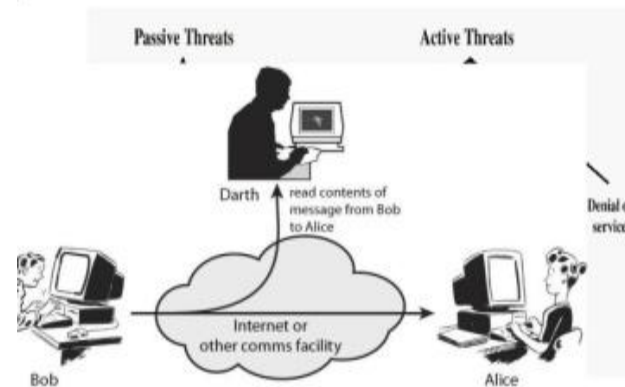
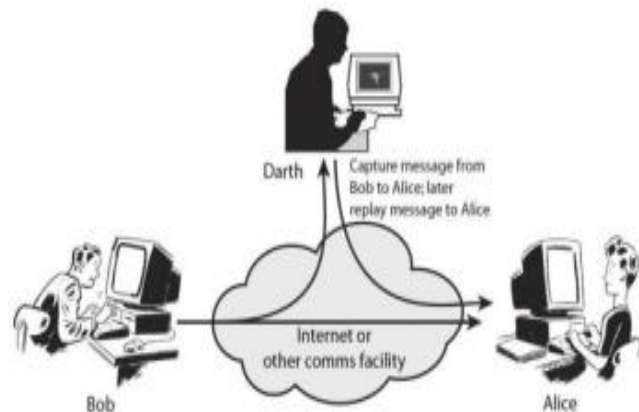
- We have **two** types of Attacks



1

Security Attack

- any action that compromises the security of information owned by an organization
 - information security is about **how to prevent attacks**, or failing
 - that to detect attacks on information-based systems
- often **threat** and **attack** used to mean same thing and focus of **generic types** of attacks: Passive and Active



- Categories of Attacks:

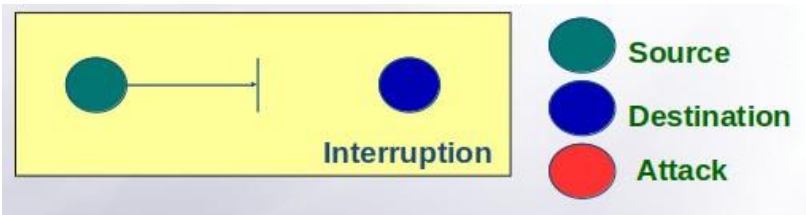
- **Interruption:** An attack on availability
- **Interception:** An attack on confidentiality
- **Modification:** An attack on integrity
- **Fabrication:** An attack on authenticity

1 **Interruption:** An asset of the system is destroyed or becomes unavailable or unusable.

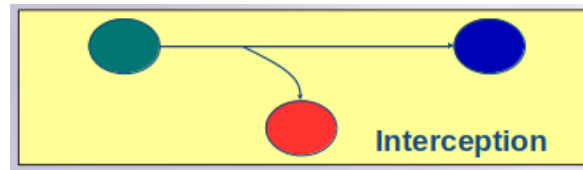
- This is an attack on availability

- **Examples:**

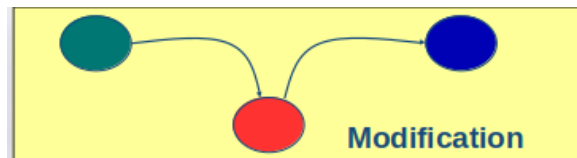
Destruction of hardware, cutting of a communication line



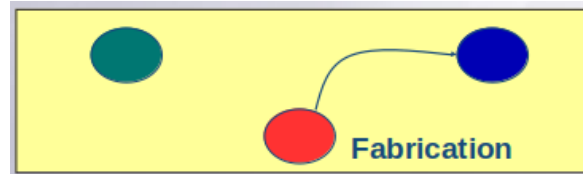
- 2 **Interception:** An unauthorized party gains access to an asset.
Unauthorized party could be a person, a program or a computer.
• **Examples:** Capture data in the network, Illegal copying of files.



- 2 **Modification:** When an unauthorized party gains access and alters an asset.
• **Examples:** Changing data file, Altering a program and the contents of a message



- 4 **Fabrication:** -An unauthorized party inserts counterfeit objects into the system.
- This is an attack on **authenticity**.
 - **Example:** insertion of spurious message in a network or addition of records to a file.

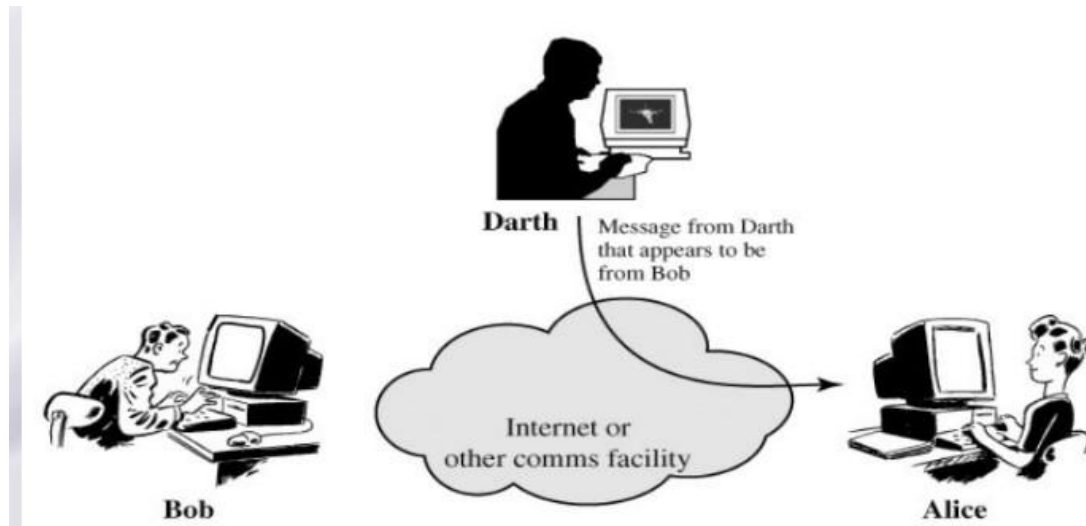


- **Active Attack**

- Active attacks involve some modification of the data stream or the creation of a false stream.
 - Masquerade,
 - Replay,
 - Modification of messages, and
 - Denial of service.

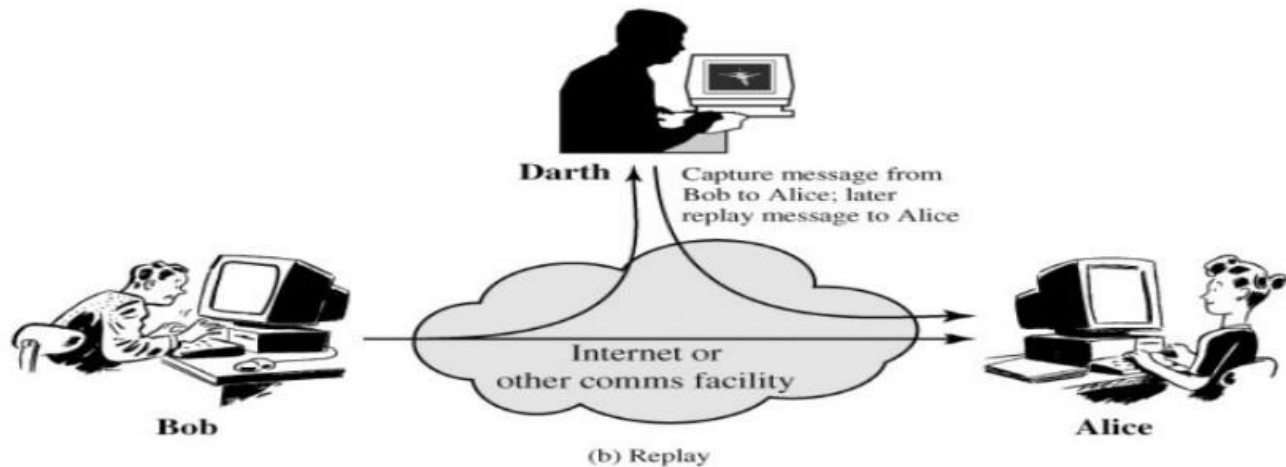
■ Masquerade

- Here, an entity **pretends** to be some other entity.
- It usually includes one of the forms of active attack.



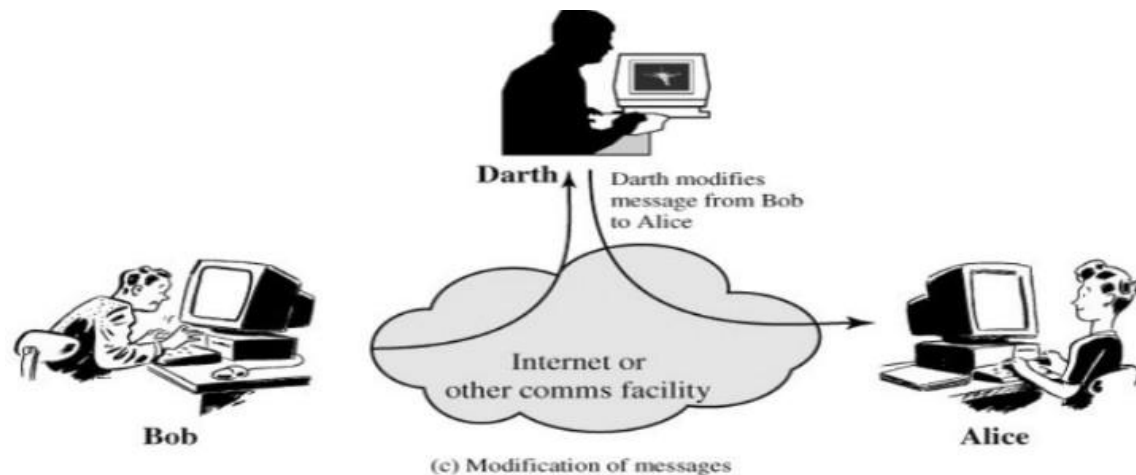
■ Replay

- It involves **capture** of a data unit and its subsequent **retransmission** to produce an unauthorized effect.
- Can take place by sending the same message twice.



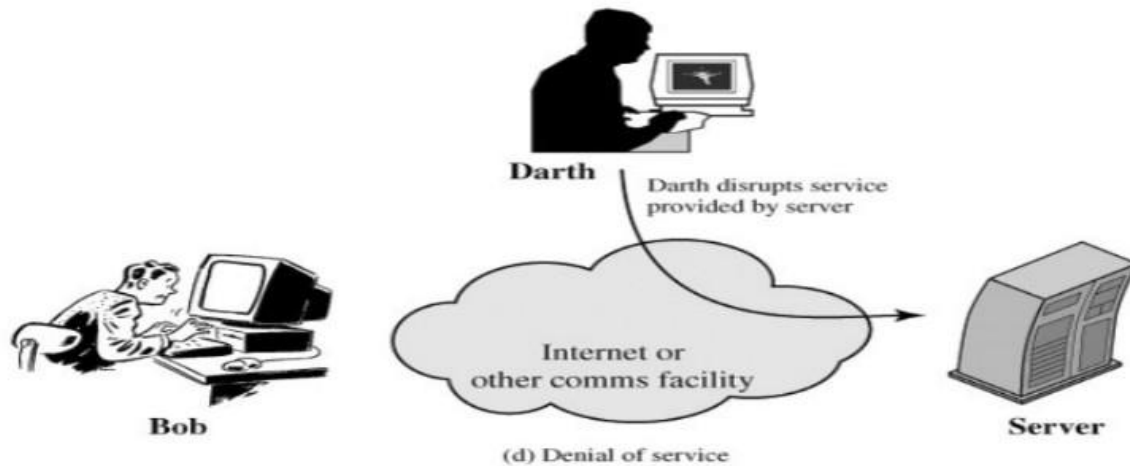
■ Modification of messages

- It means that some portion of a legitimate message is **altered**, to produce an unauthorized effect.
- **Example:** "John's acc no is 2346" is modified as "John's acc no is 7892"



Denial of service

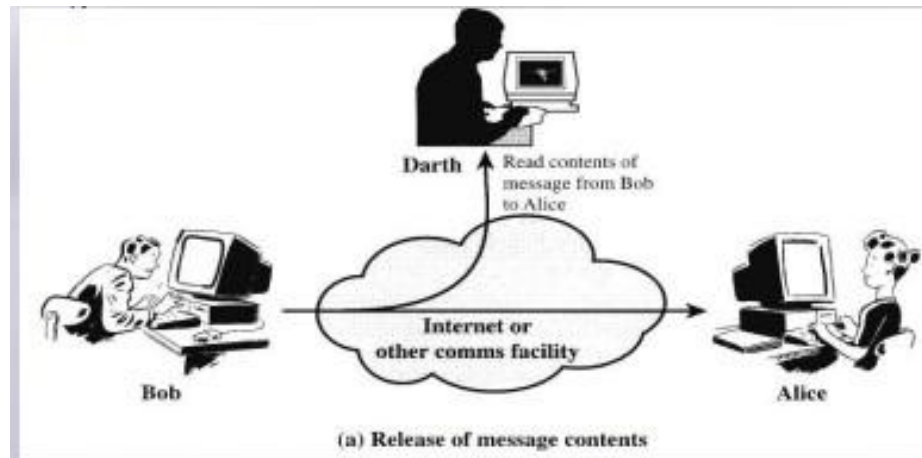
- This attack **prevents** the normal use of communication facilities.
- **Example:** a Disruption of entire network by disabling it.



- **Passive Attack**

- **Reading the message content**

- A Passive attack attempts **to learn** or make use of information from the system, but does **not** affect system resources.
 - Passive attacks are very **difficult** to detect because they do not involve any alternation of the data.



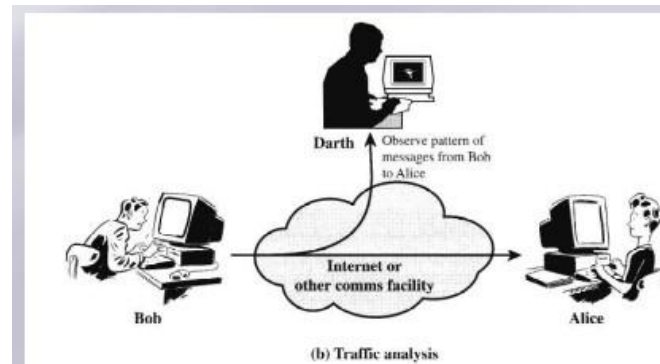
- Generally Active Attack

- It is quite **difficult** to prevent active attacks absolutely, because to do so would require physical protection of all communication facilities and paths at all times.
- Instead, the goal is to **detect** them and to **recover** from any disruption or delays caused by them.

2

■ Traffic analysis

- It help passive attacker to observe the frequency and length of encrypted messages being exchanged there by guessing the nature of communication taking place.
- The number, size, frequency and times of messages sent, their sources and their destination can be leaked from these types of analysis.



3

- **Social engineering** : It is the psychological **manipulation** of people into performing actions confidential information.

Controls

- Computer security controls are safeguards—technical, administrative, or physical—designed to protect information systems by preventing, detecting, or mitigating security risks.
- They ensure data confidentiality, integrity, and availability. Key types include preventive controls (firewalls), detective controls (log monitoring), and corrective controls (backups), often implemented in layers.

Types of Computer Security Controls

Security controls are often categorized by how they protect assets:

- **Technical (Logical) Controls:** Software/hardware measures like firewalls, encryption, antivirus software, intrusion detection/prevention systems (IDS/IPS), and multi-factor authentication (MFA).
- **Administrative (Managerial) Controls:** Policies, procedures, and guidelines such as security awareness training, password policies, and data classification.
- **Physical Controls:** Tangible barriers such as locks, security cameras, security guards, and biometric scanners.

Functional Classification

- **Preventive:** Stop incidents before they occur, such as firewalls or training.
- **Detective:** Identify and log incidents, such as security cameras or intrusion detection sensors.
- **Corrective:** Restore systems after a security incident, such as data backups or malware removal.
- **Deterrent:** Discourage attackers from attempting an attack.

Computer Security Policies and Mechanisms

- **Policies:** High-level documents, such as Acceptable Use Policies (AUP) and Access Control Policies, that define rules for information security and employee behavior.
- **Mechanisms (Controls):** The technical and operational tools used to implement policies, classified into four categories:
 - **Technical:** Firewalls, encryption, antivirus software, and intrusion prevention systems.
 - **Physical:** Locks, surveillance cameras, and security lighting.
 - **Operational/Administrative:** Incident response plans, risk assessments, and user training.
 - **Managerial:** Security oversight, compliance frameworks, and organizational policies.

Prevention, Detection, and Deterrence

- **Prevention (Before incident):** Focuses on blocking attacks through firewalls, Multi-Factor Authentication (MFA), and user training to avoid malicious activity.
- **Detection (During incident):** Uses tools like Intrusion Detection Systems (IDS), anomaly detection tools, and AI-driven behavioral analysis to detect breaches or insider threats.
- **Deterrence (Discouragement):** Measures meant to discourage attackers, such as legal warnings, banners detailing monitoring, or security auditing notices.
- **Corrective:** Measures taken after an event to limit damage, such as patching or system restoration.

Software Security Assurance

- **Definition:** A proactive approach to ensure software is designed, developed, and maintained with security considered at every stage.
- **Key Components:**
 - **Development Lifecycle:** Embedding security testing and threat modeling early in development.
 - **Vulnerability Management:** Regular scanning, penetration testing, and code analysis to detect potential bugs before deployment.
 - **Assurance Processes:** Evaluating the security posture through metrics, audits, and rigorous verification.

Thank you!